Risico-gerichte aanpak

Stevens, Bas
coördinerend senior informatiebev. en privacy

Cyberrisico's nemen snel toe in ernst en frequentie; we zien dagelijks verlammende aanvallen op prominente instellingen. Aanvallers profiteren van onzekerheid over de aanpak van cyberrisico's. Aanvallers groeien in aantal en sterkte en ontwikkelen voortdurend destructieve nieuwe strategieën. De organisaties die zijn aanvallen moeten razendsnel reageren, maar moeten ook op een slimme manier risico's verminderen in een wereld met beperkte middelen.

Van ‘de dingen goed doen’...

Het is gemakkelijk om een grote hoeveelheid middelen in te zetten in een poging om een organisatie te beschermen tegen risico's op het gebied van informatiebeveiliging en privacy (IB&P). Zonder duidelijke keuzes te maken waar deze middelen op worden ingezet, of door te pogen de volwassenheid van IB&P te verhogen over de volledige breedte van de organisatie (zoals bijvoorbeeld het overal implementeren van MFA), worden de échte risico's echter vaak niet of nauwelijks verkleind.

Het kost heel veel tijd, geld en moeite en vanwege de omvang van de verbetertrajecten voelt het als continu achterlopen. In onderstaande afbeelding wordt dit de ‘maturity-based approach’ genoemd.

Naar ‘de goede dingen doen’

Als het doel is om ons IB&P risico te verminderen, moeten wij ons inspannen om met de minste investeringen het meeste rendement te halen. Deze aanpak geldt voor alle maatregelen die wij nemen. In plaats van ‘de controle overal op te bouwen’ komt de focus te liggen op het bouwen van de **juiste** controles voor de ernstigste kwetsbaarheden om de meest significante bedreigingen te verslaan. Dit is de ‘risk-based approach in onderstaande afbeelding.

Security not considered

Security schmecurity

Lack of capability and awareness throughout organization, including among senior leadership

Maturity-based approach

Build capabilities

Strengthen essential security and resilience fundamentals to plug gaps

Establish cyber operating model and organization to professionalize cybersecurity function

Risk-based approach

Reduce enterprise risk

Identify, prioritize, deliver, manage, and measure security and privacy controls in line with enterprise-risk-management framework

Set risk-appetite thresholds for linked pairs of key risk indicators and key performance indicators

Include stakeholders from full enterprise in cyber operating mode

Proactive cybersecurity

Achieve holistic resilience

Transform processes and adoption of next-generation technologies to reduce detection and response times to within recovery-time objectives

Embed security in technology products, services, and processes from point of inception through to execution to achieve complete "security by design"

Fully incorporate customers, partners, third parties, and regulators into management of enterprise resilience

Example activities

- Assess cyber maturity (eg, data protection, access management) with or without benchmarks to highlight capability

Example activities

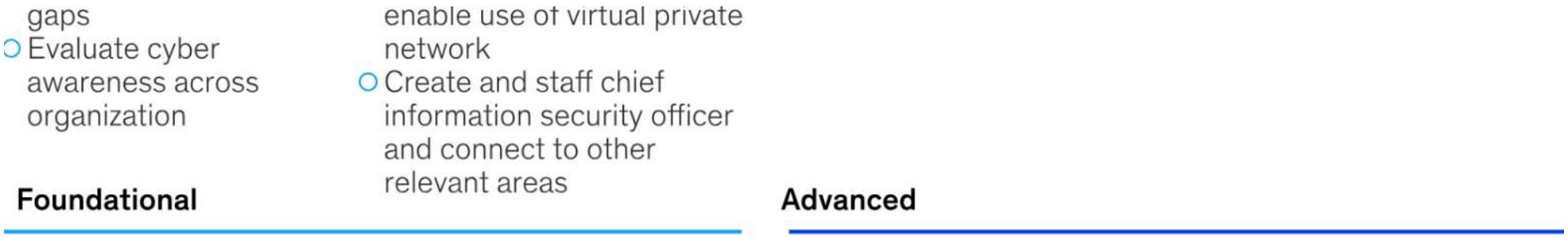
- Build security operations center, incident-response playbooks, and identity- and access-management function; install multifactor authentication on apps;

Example activities

- Implement cyberrisk quantification
- Measure and report on reduction of risk, not progress of capabilities

Example activities

- Deploy advanced analytics and machine learning for preventative detection
- Implement security by design with multilayer response-time reduction



Bron: McKinsey Risk Based Approach to Cybersecurity

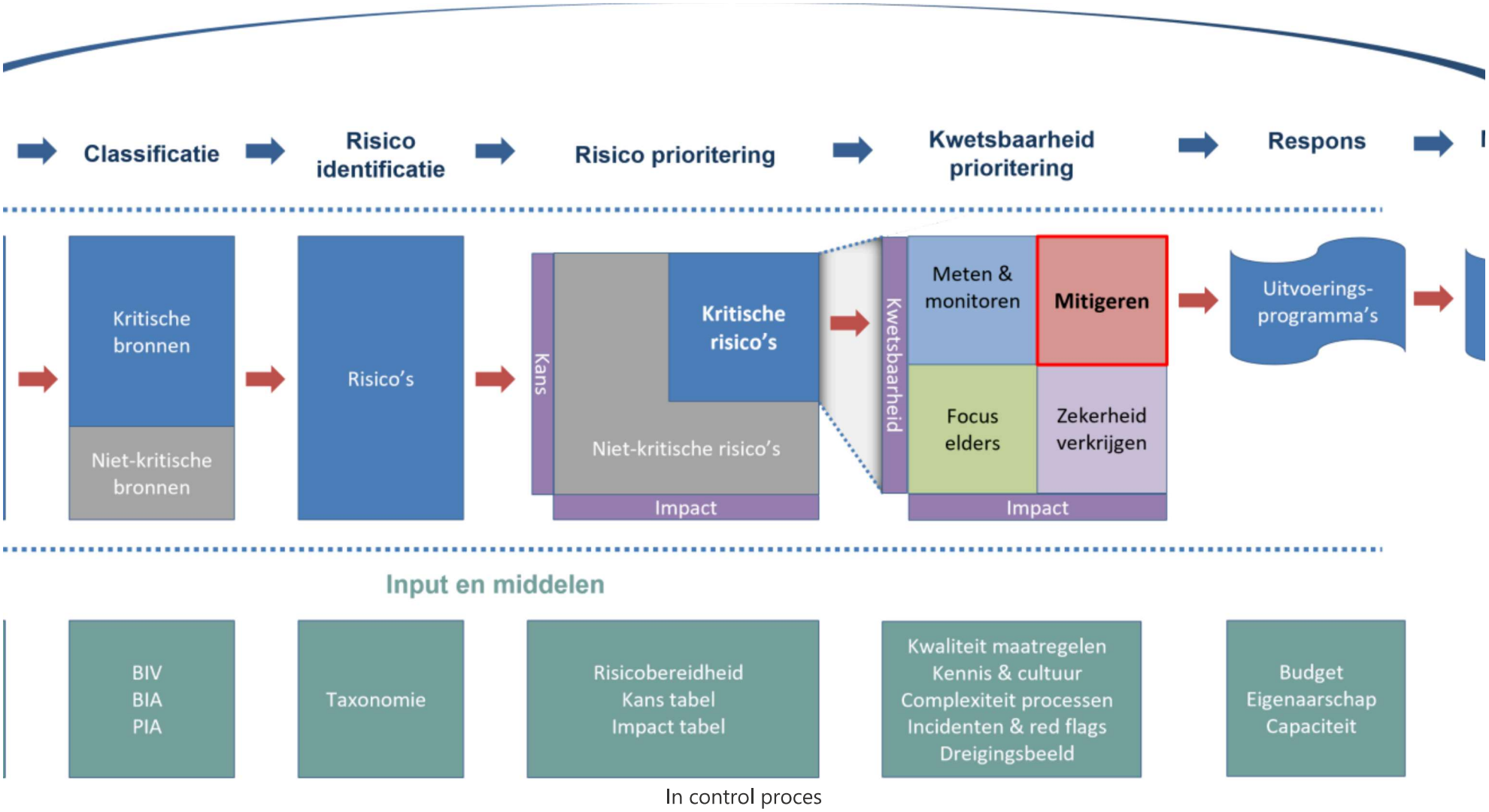
In het kort...

Een op risico gerichte benadering van cybersecurity is essentieel om effectief en efficiënt om te gaan met de steeds evoluerende en toenemende cyberrisico's. Deze benadering stelt ons in staat om onze risico's te begrijpen en te prioriteren, onze middelen effectief te gebruiken en onze risico's effectief te verminderen tot een acceptabel niveau.

Hoe wij dit aanpakken

Onderstaande afbeelding laat zien, van links naar rechts, dat wij starten met de inventarisatie van alle **waardebronnen** (assets). Dat is het startpunt. Wanneer de meest kritieke bronnen van waarde duidelijk zijn na deze te classificeren, bepalen wij de mogelijke risico's die de vertrouwelijkheid, integriteit, beschikbaarheid of rechtmatigheid van die bronnen kan beschadigen: potentiële impact en de kans dat dat plaatsvindt, zonder enige vorm van maatregelen (dit noemen wij inherente of bruto risico's). De meest impactvolle en meest aanstaande risico's noemen wij onze **kritische risico's** en daarmee moeten wij aan de slag. Voor elk van dit kaliber risico's proberen wij te beoordelen hoe kwetsbaar wij binnen de Leidse Regio zijn, door te kijken naar o.a. onze cultuur, paraatheid en status van beheersmaatregelen. Zo komen wij tot de

kans en impact van die kritische risico's en vormt een beeld van onze **ernstige kwetsbaarheden**. En deze pakken wij aan door middel van uitvoeringsprogramma's: mitigeren.



Mitigeren: onmiddellijke actie via uitvoeringsprogramma's
Zekerheid verkrijgen: kwetsbaarheid valideren via audits

Meten & monitoren: kwetsbaarheid monitoren voor cumulatief risico
Focus elders: kwetsbaarheid accepteren

Meer info over deze aanpak

Mitigeren: onmiddellijke actie via uitvoeringsprogramma's. Dit zijn risico's met een hoge impact waarvoor de organisatie een hoge kwetsbaarheid heeft - dat wil zeggen, risico's waarvoor de inspanningen van de organisatie relatief ineffectief zijn geweest om het risico op een niveau te houden dat overeenkomt met de risicobereidheid. Voor deze risico's moeten risico-eigenaren overwegen om middelen te investeren in het ontwikkelen en ontwerpen van controles om blootstelling te verminderen, evenals het volgen van de voortgang van herstelplannen.

Zekerheid verkrijgen: kwetsbaarheid valideren via audits. Dit zijn risico's met een hoge impact waarvoor de organisatie een lage kwetsbaarheid heeft - dat wil zeggen, de risico-eigenaars beschouwen de mitigatie-inspanningen van de organisatie als voldoende om het niveau van elk risico binnen de risicobereidheid te brengen. Voor risico's in dit kwadrant moeten risico-eigenaars redelijke zekerheid kunnen bieden aan het management dat de controles om een risico te voorkomen, detecteren, corrigeren of escaleren, nog steeds zowel effectief als efficiënt zijn om de kwetsbaarheid voor dat risico binnen de risicobereidheid van het bedrijf te houden. Interne audit of interne controle (of andere processen) kunnen worden gebruikt om de zekerheid te valideren.

Meten & monitoren: kwetsbaarheid monitoren voor cumulatief risico. Dit zijn risico's met een lage impact die momenteel adequaat worden beheerst door de inspanningen van de organisatie. Gezien hun relatief lage impact moet een organisatie overwegen of ze meer uitgeeft om deze risico's te beheren dan noodzakelijk is, en of ze middelen van risico's in dit kwadrant moet overhevelen naar risico's in het Mitigeren-kwadrant.

Focus elders: kwetsbaarheid accepteren. Dit zijn lage-impactrisico's waarvoor de organisatie een relatief hoge kwetsbaarheid heeft. Het kan de moeite waard zijn om te overwegen of de risico's in dit kwadrant gezamenlijk een significantere impact op de organisatie kunnen hebben, en zo ja, waar het nieuwe, geaggregeerde risico op de grafiek zou vallen. Voorbeeld: een reeks kwaliteitsrisico's kan elk een relatief lage impact hebben wanneer ze afzonderlijk worden beschouwd, maar kan een grotere impact en betekenis hebben wanneer ze als groep worden beschouwd

Risico-gericht versus volwassenheid-gericht

Een mooi voorbeeld is een organisatie die simpelweg haar beveiligingsinitiatieven heeft herschikt volgens de risico-gerichte benadering, waardoor het verwachte risicovermindering 7,5 keer hoger ligt dan het oorspronkelijke programma. Zonder extra kosten. Hieronder nog een voorbeeld van de risico-gerichte aanpak (links) organisaties meer rendement oplevert dan de volwassenheid-gerichte aanpak (rechts).